Mitigation Plan

Practical security recommendations drawn from the Coincheck NEM theft

Prepared by: Kshitij Randhire

Project: Cryptocurrency Exchange Hack Investigation (independent research project)

---

1. Purpose

This plan is for a crypto exchange that wants to avoid a repeat of the Coincheck theft, or to react better if one happens. Each recommendation is tied to something I found in the case. I marked each row as **Case evidence** when the case supports it directly, and as **Good practice** when it is a sensible control that the case does not prove on its own.

2. What went wrong

Gap	Evidence
One key could move the funds	All 11 transfers out of the wallet were plain transfers signed by one key, with no co-signatures.
Large balance kept online	The COO and the BBC both said the XEM was in a hot wallet, not cold storage.
Nobody noticed for hours	The first transfer left at 00:02 and the first 100 million XEM at 00:04. Coincheck noticed at 11:25.
A brand-new address received the money	Address B had no history before the 10 XEM test transfer, and then received 526 million XEM.
Thin security resources	The president cited technical difficulties and a shortage of staff.

3. Immediate actions (first 24 hours)

In the first day the aim is to stop further loss and keep the evidence. Redesigning anything can wait.

Action	Why	Basis
Suspend withdrawals and trading for the affected asset straight away.	Coincheck froze everything except Bitcoin after detection (BBC). While a theft is running, each minute matters.	Case evidence
Record the destination addresses and share them at once with other exchanges and the asset's foundation.	Coincheck knew where the coins went (BBC), and the NEM Foundation announced tagging within one to two days. The coins were split across eight addresses in about 33 minutes, so early sharing gives tagging a head start.	Case evidence
Treat the signing key as compromised. Move any remaining funds to new offline addresses and retire the old keys.	The theft transfers were signed by the wallet's own key, so whoever holds it can keep moving whatever is left.	Case evidence

Action	Why	Basis
Preserve evidence before anything is rebuilt: logs, disk images, memory, network records and access history of the wallet servers and staff machines.	No internal data is public here, and the way the attacker got in is still unknown.	Good practice
Report to the police and the financial regulator without waiting for the root cause.	The FSA acted within days (30 Jan transcript).	Good practice
Tell customers what is known and what is not, and say when the next update will come.	Coincheck announced its refund plan within two days (BBC).	Case evidence

4. Short-term actions (1 to 7 days)

Action	Why	Basis
Audit every wallet and every asset for the same weak setup: single key, hot storage, no alerts.	One asset was hit here, but the FSA asked other dealers to check their own systems.	Case evidence
Switch on alerts for every hot wallet: any single large transfer, and total outflow in a short window.	Seven transfers moved 523 million XEM in 17 minutes. An alert on the first 100 million would have fired about 11 hours before detection.	Case evidence
Move most of the remaining hot-wallet balances to cold storage and keep only what daily withdrawals need.	The exposed balance is what an attacker can take.	Case evidence
Publish a refund or recovery plan with dates, and keep to them.	Coincheck pledged more than 46 billion yen. Customers need timing as well as an amount.	Case evidence
Name one incident lead and one communications lead, and keep a log of decisions.	Keeps the response coordinated and gives the regulator a record.	Good practice

5. Long-term measures (30 to 90 days and beyond)

Measure	Why	Basis
Require multiple signatures on every hot wallet for every asset, with keys held by different people on different devices.	One compromised key was enough for a total loss of the balance in the wallet.	Case evidence
Write a policy for how much may sit in hot wallets, with cold storage for the rest and a fixed top-up process.	Makes the limit a written rule that can be checked, instead of a choice made asset by asset.	Case evidence
Hold large withdrawals for review, and flag transfers to addresses that have never been seen before.	The first destination address had no history before the test transfer.	Case evidence
Build real-time monitoring that pages an on-call person, and test it with drills. Reconcile wallet balances against customer ledgers every day.	The gap between theft and discovery was 8.5 to 11 hours.	Case evidence

Measure	Why	Basis
Review key management: who can reach signing keys, where they are stored and how they are backed up. Use offline signing or hardware security modules for large wallets.	The attacker could sign with the wallet's key, and how they reached it is unknown.	Good practice
Add security staff and training, and do not leave the work to a few people.	The president cited a staff shortage.	Case evidence
Get an independent security audit every year and after any major change.	Outside review finds gaps that internal teams miss.	Good practice
Keep a written incident response plan, test it twice a year, and include regulator and customer message templates.	Coincheck's response after detection was fast. Writing it down makes it repeatable.	Good practice
Name a compliance owner who tracks regulator requirements and keeps evidence of the controls.	The FSA issued a formal improvement order after the theft.	Case evidence

6. Risk view

Scores use a 1 to 5 scale for likelihood (L) and impact (I). Rating is L times I. The scores are my own judgement for an exchange with the same setup as Coincheck had, not measured values. Table 1 defines each score so another reviewer can apply the same scale, and Table 3 gives the reason for each score.

Score	Likelihood in the next 12 months, for an exchange set up as Coincheck was	Impact if it happens
1	Rare: needs several independent failures; no route in the case evidence.	Negligible: no customer assets lost; no disruption beyond minutes.
2	Unlikely: needs a deliberate, targeted effort against a control that is in place.	Minor: small loss absorbed by normal operating funds; short, limited disruption; no regulator action.
3	Possible: a credible route exists and a partial control is in place.	Moderate: material loss met from company reserves; withdrawals paused for hours to days; regulator inquiry likely.
4	Likely: a known route exists and no effective control stops it, as at Coincheck.	Major: loss large enough to need outside funding or threaten solvency; multi-day suspension; formal regulator action.
5	Almost certain: the route is easy, widely known and already used against this exchange.	Severe: loss of most customer assets or of the business; extended freeze; formal order and widespread customer harm.

Table 1. Scoring criteria.

Rating bands: Low is 1 to 6, Medium is 7 to 14, High is 15 to 25. For scale, the Coincheck outcome is an impact of 5: about 58 billion yen lost, about 260,000 customers affected and a formal FSA improvement order.

Risk	Before	Main control	After
Theft from a single-key hot wallet	L4 x I5 = 20 (High)	Multisig, cold storage, hot-wallet cap	L2 x I3 = 6 (Low)

Risk	Before	Main control	After
Theft goes unnoticed for hours	L4 x I4 = 16 (High)	Real-time alerts, on-call, daily reconciliation	L2 x I3 = 6 (Low)
Signing key exposed through staff or systems	L3 x I5 = 15 (High)	Key management review, offline signing	L2 x I4 = 8 (Medium)
Slow or confused response after a breach	L3 x I3 = 9 (Medium)	Tested response plan, named leads	L2 x I2 = 4 (Low)

Table 2. Simple likelihood and impact assessment.

Table 3 gives the reason for each score, using the criteria in Table 1.

Risk	Before: why	After: why
Theft from a single-key hot wallet	L4: the exact setup was exploited at Coincheck, so no effective control stood in the way. I5: the whole hot-wallet balance went (526,300,010 XEM) and an FSA order followed.	L2: needs two or more independent keys to be compromised. I3: a hot-wallet cap limits the loss to a working balance that reserves can cover.
Theft goes unnoticed for hours	L4: nobody reacted for about 11 hours in the case, and public sources do not show any alerting. I4: the loss was complete before anyone reacted; scored one step below risk 1 so the same loss is not counted twice.	L2: real-time alerts and an on-call person remove the quiet window. I3: minutes of exposure limit how much can leave.
Signing key exposed through staff or systems	L3: how the attacker reached the key is unknown (Incident Report, Section 4), so the route is credible but unproven. I5: an exposed key gives full control of the wallet.	L2: offline signing and hardware security modules make key theft harder. I4: with multiple signatures one exposed key is not enough alone, but it still forces a key rotation and an investigation.
Slow or confused response after a breach	L3: Coincheck's response after detection was fast (BBC), so a failure is possible but not shown. I3: a slow response lengthens the freeze and weakens customer and regulator trust.	L2: a tested plan and named leads. I2: a practised response keeps the extra harm short.

Table 3. Reasons for the scores in Table 2.

7. Where I would start

If I could do only two things first, I would do multisignature and real-time alerts. Most of the other items reduce the chance of a breach or the time it takes to spot one. Multisignature changes what a single stolen key can cost, and an alert on the first large transfer would have turned an 11-hour theft into a few minutes.

8. Limits of this plan

It is based on public information about one incident. I do not know Coincheck’s internal setup beyond what officials said, so I have not judged how hard each measure would have been for them. Some measures cost money or slow withdrawals, and an exchange has to balance that against customer convenience.